PILLAR 5 GMBH | REVIEW DRAFT | 25 OCTOBER 2026

Basel AI Audit Trail

The plan for the public demo, written so it can be read before the BaselTech call. The shaded notes say why each choice was made.

Applicant. Pillar 5 GmbH, Basel. **Call use.** Three-minute introduction. **Status.** Plan only. Nothing is built yet. This PDF contains no private keys.

Executive summary

The tool shows, on sample invoices, where an AI got each fact, and it will not finish until a person says yes.

1. You open a sample pack: an order, a delivery note, and an invoice. The papers are invented.
2. The AI only points at the line it used. It does not fill in the numbers itself.
3. The program reads that line and fills the form. If two papers disagree, the box stays empty.
4. You check the form. You approve it, or you hold it.
5. Only after approval is there a final note. A link lets someone check that the note was not changed later.

Nothing on the page is a real company file. No private keys appear on the page, in the downloads, or in this PDF.

What this document is

This is the build plan for a public page Gian can share on the funding call. It is not a funded result, and it is not a claim that a Basel client has signed. The product is a method demonstration: two synthetic supplier-invoice dossiers, a model that only points at a printed segment, a rule file that derives the record, and a person who must approve before a Prüfvermerk exists.

The original application promised a working prototype, human approval, an integrity check, an open demo on synthetic data, and reusable documents. This plan keeps those promises and is stricter than the text that was submitted. The model does not write the answer. The browser can recompute the seal.

> WHY A REVIEW NOTE, SEPARATE FROM THE PRODUCT
>
> The plan file in the editor is an instruction to build. This PDF is the same instruction with the reasons left in, so a decision can be changed before any code exists. The reasons come from the application text, from BaselTech's four open questions, and from a review by Opus, Argon, and Muse on where a live model drifts.

The three minutes

The address opens on a chooser, not on an invoice. The title is Basel AI Audit Trail. One line says the documents are synthetic. Fall Abweichung has a gold edge and the label "Für das Gespräch". Fall Klar is the quieter control and still opens.

1. Read the title, the synthetic-data line, and the gold card.
2. Open Fall Abweichung. The loader is the KI-Unterstützung step. The gold crop on the printed segment is Extraktion. The empty conflict is Unsicherheit.
3. Show the block "Entwurf des Werkzeugs", and the line that the model can be replaced.
4. Type a name, press Freigeben, and read the Prüfvermerk. That is Human Review.

5. Open the verify link, then the broken example. That is the audit trail and the integrity check.
6. Point at the KPI strip and the five downloads. That is Evaluation. Say that 30% and 90% are still targets.

Fall Klar is the answer if someone asks what a clean invoice does. It is not the opening, because a clean file hides the uncertainty step.

> WHY THE CALL STARTS ON THE MISMATCH
>
> BaselTech asked for a defined workflow and a way to see improvement. A matching invoice only shows a happy path. Fall Abweichung carries the three defects named in the plan: quantity disagrees, the cost centre is missing, and the VAT rate disagrees. Those are the moments the method is for. The chooser exists so the first ten seconds of a screen share are the title and the dossier to open, not a wall of figures.

What the page will show

Accountable person on the page: Gian Seyitcan Senpinar, Pillar 5 GmbH, Basel. No client organisation is signed. Felix Ritzi's dual role is not discussed on the page.

The work product is a Prüfvermerk: book or hold, amounts, exceptions, the segment ids, the name the reviewer typed, and the time. It appears only after approval. Rejection stores a hold. Before approval, a separate block labeled "Entwurf des Werkzeugs" shows the same template filled by the rules. That block is a draft.

A status rail uses the eight words from the application: Eingang, Extraktion, Unsicherheit, KI-Unterstützung, Human Review, Audit Trail, Integrität, Evaluation. The database stores five events: intake, extraction, derivation, decision, seal. The rail is the caller's map. It is not a second log.

The look follows the tools already shipped, translated into Pillar 5 gold **#c9a962** on a white page: hairline rules, square buttons of at least 44 pixels, Source Sans 3, Source Serif 4 only for the Prüfvermerk title. No chat, no confidence score, no rule editor. On a phone the documents come first, then the fields, then a full-width decision bar. Inputs are 16 pixels so the phone does not zoom. There is no sideways scroll at 390 pixels or at 1440.

Selecting a field scrolls to that segment. The segment is outlined in gold, with the sentence "Das Werkzeug hat diesen Text hier gelesen." The model is named once, on the extraction line, next to the version of the rule file.

> WHY EIGHT LABELS AND FIVE STORED EVENTS
>
> A guest who has read the application will look for those eight words. If the screen uses only the internal event names, the demo feels smaller than the proposal. Storing eight rows would repeat the same fact: uncertainty is the result of derivation, and evaluation is the strip of counters. The chain a person recomputes on the call stays short on purpose.
>
> WHY THE DRAFT IS VISIBLE BEFORE APPROVAL
>
> If the tool's result appears only after Freigeben, the middle of the call has nothing to talk about. The draft shows that the rules already ran. The word Prüfvermerk is reserved for the sealed record, so a guest cannot mistake the draft for a final booking.
>
> WHY THE DUAL ROLE STAYS OFF THE PAGE
>
> BaselTech asked how Pillar 5 and Ritzi DeFi relate, because Felix is also listed as Pillar 5's CTO. A sentence on a public page would guess at that relationship. The clarification belongs in the separate letter, not in a demo.

The tool, and the model's small job

The Worker loads four files. The browser cannot replace them.

- **dossiers.json** splits each document into stable ids and the exact text, for example RE-12. The id is printed on the document.
- **schema.json** lists eight fields: supplier, invoice number, date, net, VAT rate, gross, order reference, quantity.
- **rules.json** holds the business logic: Swiss number parsing, a conflict when two segments normalize differently, a missing field when none match, net times (1 + rate) equals gross within one cent, and book versus hold.
- **gold.json** is the authored reference reading of these same two dossiers.
- **templates.json** holds the German sentences. The tool fills the blanks.

The model receives the segment list and returns, per field, only ids from that list. Temperature is 0. One call. If the endpoint accepts a seed, the call sends 510 and stores it on the event. The derived record does not depend on the seed. An id that is not in the dossier file is dropped. The Worker parses the segment text itself. Two different parsed values become a conflict: the field stays empty and both segments stay cited. A failed VAT check empties net, rate, and gross. The tool does not invent a corrected total.

The same function runs on the model's ids and on the reference reading. The only difference a second run can introduce is a different set of ids. When the ids match, the Prüfvermerk text matches.

The model in the first version is **openai/gpt-6.1-sol** through OpenRouter. The page says: "Methode: rules.json. Das Modell kann ausgetauscht werden." The credential that calls the model stays on the server. It is not written into this PDF, the page, the downloads, or the repository.

> WHY THE MODEL DOES NOT EXTRACT THE NUMBER
>
> Opus, Argon, and Muse reviewed this split. A model that returns character offsets slips by a letter. German punctuation and the thousands separator turn 1.000,00 into a different amount, and the VAT check then fails for a reason that is not in the invoice. A model that returns the number itself is using its own knowledge of what an invoice should say. A seed does not keep two OpenRouter backends on the same bytes.
>
> The closed list of segment ids removes that freedom. The model's only judgment is which printed line bears on the field. Parsing, conflict, arithmetic, and the German sentences are functions of the files. That is what similar outputs means here: the same chosen ids always produce the same record. Asking the model for a confidence score was rejected. It would look like a measurement, and it is not calibrated. The rules already decide.
>
> WHY A SEED IS STILL SENT
>
> When the endpoint accepts it, the seed is an extra stabilizer and the audit event records that it was used. It is not the guarantee. The guarantee is the rule file plus the id list.
>
> WHY THIS MODEL, AND WHY IT CAN BE NAMED ONCE
>
> The functioning demo needs a live call, and GPT-6.1 Sol was the model requested. The application also promised a vendor-neutral method. Pinning the screen to one brand would contradict that. The method line, and the fact that the sentences come from the template file, are how the page keeps the promise while still showing a real model on the day.

The audit record

Opening a dossier creates a session and a verify link. There is no login. The typed name is stored as a claim. The page says the chain records when the name was written, and does not prove who typed it.

Each event is canonicalized with RFC 8785 (JSON Canonicalization Scheme). The hash is SHA-256 of a domain tag, a newline, and those canonical bytes. The first event's previous hash is 64 zeros. Separate tags cover the raw document bytes, the rule file, the schema, and the raw model response. The seal stores the hash of the Prüfvermerk. The verify link carries the seal hash in the fragment. The browser recomputes the chain from the stored canonical bytes and checks that fragment. A fixed broken example shows the red state.

The page says this proves the copied link still matches the log. It does not prove an outside witness. One decision and one seal are allowed per session. A repeat returns the existing seal.

> WHY THIS HASH, AND WHY NO BLOCKCHAIN
>
> Sorting JSON keys is not a stable canonical form. Number format, escapes, and nested order still differ between languages, so two correct programs can hash different bytes. A hash of previous hash plus payload also ignores the event type and the document bytes: those can change while the links still look valid. Domain tags stop a hash of the prompt being substituted for a hash of the document.
>
> The fragment in the link is the reviewer's own copy of the seal. If the log is rewritten after the link was shared, the old link turns red. That is the property a guest can see on the call. It is not a public timestamp and not a second organization holding a copy. A blockchain was left out because the application forbids putting document content on a public chain, and a single operator does not gain an independent witness by writing to one. A timestamp service was left out for the same reason: the operator could stamp a rewritten log. A Merkle tree over a handful of rows adds machinery and no second witness.
>
> WHY THE NAME IS CALLED A CLAIM
>
> The demo is public and has no accounts. Treating a typed name as identity would make the audit record say something it cannot know. The honest sentence is part of the record a funder can read.

What is measured

A strip titled "KPI-Hypothesen, vor dem Pilot" uses the six names from the application. The numbers are this session only. The 30% and 90% figures stay labeled as targets for a later signed pilot.

NAME IN THE APPLICATION	WHAT THE PAGE SHOWS
Effizienz	Time from the tool result to the decision. No invented baseline, and no percentage.
Nachvollziehbarkeit	Fields with a checked segment, out of eight.
Menschliche Kontrolle	Yes only after a decision.
Auditierbarkeit	The five stored events are present, and the eight labels have been reached.
Reproduzierbarkeit	A reread compares the new id set with the sealed set. Match and difference are both shown.
Wissenstransfer	Five downloads on the page. The application asked for at least three.

Agreement with the authored reference reading is an extra counter next to Nachvollziehbarkeit. A conflict counts only when the field stays empty and both segments are cited.

Five German downloads, generated from the same JSON and linked on the review screen: the workflow template, the human-approval checklist, the source checklist, the KPI schema, and a short lessons note. The lessons note says what the demo shows and what is still open: no signed client, no measured 30%, and the partner letter is not on this page.

WHY THE PERCENTAGES ARE NOT FILLED IN

The application itself calls the 30% and 90% figures hypotheses, not results already achieved. It also says the specific audit trail had not been built at the time of filing, and that the grant is not retroactive. A demo that displayed "30% saved" would contradict both sentences. There is no measured manual baseline at a Basel firm, so the page does not invent one. The honest comparison available today is the authored reading of these two synthetic files, under the same rules.

WHY FIVE DOWNLOADS

The proposal listed an open demo, a workflow template, a KPI schema, a human-review checklist, a source checklist, and a lessons note. Three of those were already in the plan. The KPI schema and the lessons note were the two a guest could notice as missing. The lessons note is allowed to list open points. It is not a report of a pilot that has not been run.

What keeps the call from breaking

The browser sends a dossier id only. The Worker inserts the fixed segments as data and does not send the reviewer's name or comment to the model. The token budget stays small. Create and reread require an idempotency key. One successful reread is allowed per session. A daily counter stops further model calls, including timeouts. Only the two dossier ids are accepted. If the model call fails, the screen shows the error and a retry. It never substitutes a canned extraction and labels it as the model.

The Cloudflare account must be able to parse the model response. The free CPU cap is too small for that parse. The call stays on the request and aborts at 45 seconds.

The stack is one Cloudflare Worker, a Vite React page, and D1, on the account Gian Seyitcan Senpinar @Pillar5. The public repository is **Giansensey007/basel-ai-audit-trail**. Deploy waits until the phone and desktop checks below are green.

WHY THE PUBLIC PAGE CANNOT ACCEPT UPLOADS

An open upload box would turn the Worker into a paid proxy for anyone on the internet, and it would put uncleared documents into the model call. The meeting also has to be repeatable. Two fixed dossiers are the whole input. A later pilot with a signed organisation can add a private intake. That is outside this build.

WHY A WORKER, RATHER THAN A STATIC PAGE ONLY

The key cannot sit in the browser. The dataroom, the expense tool, and the auction already ship as Workers on this account, and a new Cloudflare app is expected to be a Worker. The result is still a public page with a shareable address.

Phone, desktop, and when it is finished

After the screen exists, ten agents on Grok 4.7 use the live page. Each has one script, clicks through it, and takes a screenshot at every step it claims. A written description without a screenshot does not count. They do not edit the code. A defect is fixed only when a screenshot shows it. Failed scripts are run again. Five rounds at most. Regions that already passed are not restyled. Viewports are 1440 by 900 and 390 by 844.

The ten scripts cover the chooser, both dossiers, both widths, every citation, the approval gate, the verify link and the broken example, a long name with umlauts, the retry state, keyboard focus, and reduced motion. A script passes when the crop is visible, Fall Abweichung keeps the conflict empty, the Prüfvermerk appears only after approval, and no text is cut off. The repository is pushed and the Worker is deployed only after phone and desktop both pass. The same path is then checked once on the public address.

WHY THE FINISH LINE IS A USED SCREEN, NOT A RENDER

The call will be a screen share, and someone may open the link on a phone afterwards. A single desktop screenshot can hide a decision bar that sits under the fold, a crop that scrolls away, or a button that is too small to tap. The agents are there to use the tool the way a guest will. The cap of five rounds, and the rule against restyling a passing region, stop the loop from becoming a redesign.

Left out, on purpose

LEFT OUT	WHY
A named Basel client	None is signed. Inventing one would be a false statement in the meeting.
The Pillar 5 / Ritzi DeFi letter	It is a separate clarification. The page does not guess it.
Login	The demo has to open in one click on a call. The name is labeled as a claim instead.
File upload, a second model, confidence scores	They add cost, drift, or a false sense of measurement.
Any sentence that 30% or 90% has been met	Those figures are hypotheses in the application, and there is no signed pilot yet.

Order of work

1. Write the JSON files. Segment ids are the only vocabulary the model is given.
2. Scaffold the page, the Worker, D1, and the loader that runs while ids are chosen.
3. Derive values, conflicts, the VAT check, and the draft only from the rule file.
4. Hash events with RFC 8785 and the domain tags. Verify in the browser, including the link fragment.
5. Build the German screen: chooser, eight step words, gold crop, draft, approval, phone stack.
6. Run the ten-agent phone and desktop loop, up to five rounds.
7. Connect the model from the server, push the public repository, and deploy. The credential stays off the page and out of the repository.

Tests that do not call the network: an unknown id is dropped, a VAT failure empties the amounts, a conflict stays empty, a fixture id set matches the reference reading, a seal is refused without a decision, a tampered canonical byte breaks the chain, and the same id set yields the same Prüfvermerk text. One live call on Fall Abweichung is made after the server credential is in place.